

QUAL-KI Agentic SOC — Full Project Documentation

> A Healthcare-Focused Quantum-Classical AI Security Operations Center Prototype

Table of Contents

1. [Project Overview](#1-project-overview)
2. [Architecture](#2-architecture)
3. [ML Pipeline — Quantum + Classical](#3-ml-pipeline--quantum--classical)
4. [Dataset & Feature Engineering](#4-dataset--feature-engineering)
5. [Agentic Workflow](#5-agentic-workflow)
6. [Agent Descriptions](#6-agent-descriptions)
7. [Compliance Evidence System](#7-compliance-evidence-system)
8. [Streamlit Dashboard](#8-streamlit-dashboard)
9. [Demo Log Files](#9-demo-log-files)
10. [Running the Application](#10-running-the-application)
11. [Configuration Reference](#11-configuration-reference)
12. [Key Findings & Limitations](#12-key-findings--limitations)

1. Project Overview

****QUAL-KI**** (Quantum-AI Security Operations Intelligence) is a healthcare-focused ****Agentic SOC**** prototype that demonstrates:

- Real-time ****security alert processing**** using a multi-agent AI pipeline
- ****Quantum Machine Learning (QML)**** — a 6-qubit Variational Quantum Circuit (VQC) for attack classification
- ****Classical ML**** — a trained LightGBM model running in parallel for benchmarking

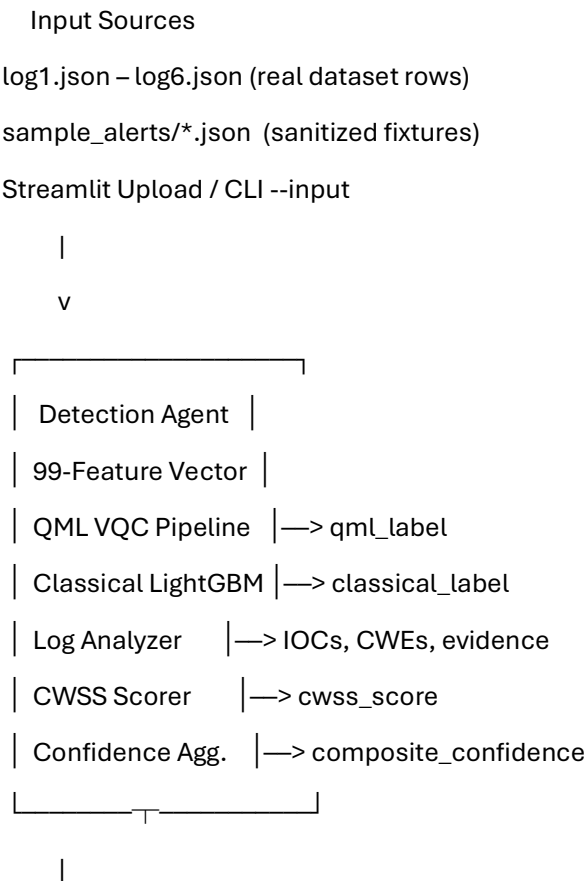
- **LLM reasoning** via Google Gemini-3.5-Flash for triage, forensics, compliance, and response
- A **compliance evidence mapping** system across HIPAA, NIST, ISO 27001, GDPR, and more

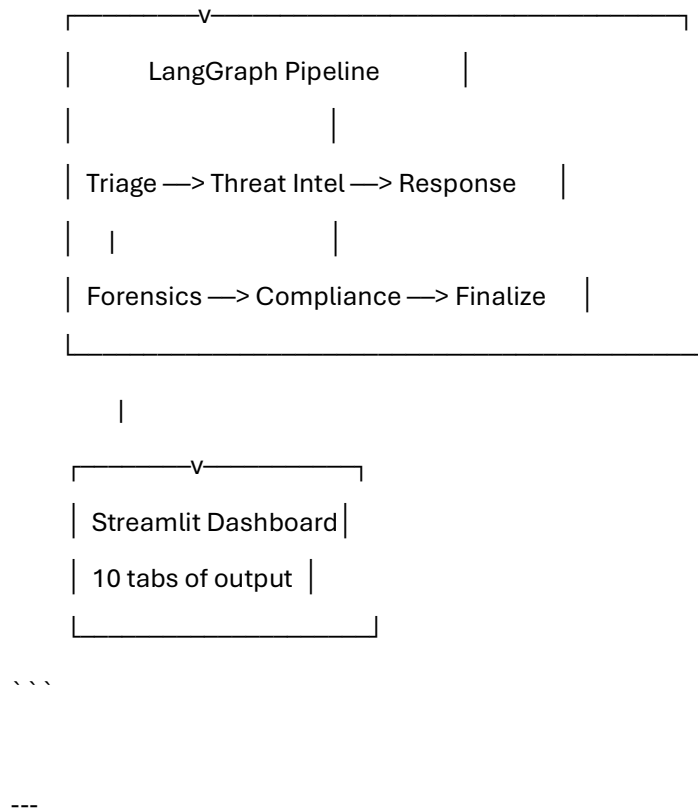
The system accepts real SIEM-style JSON logs and routes them through a **LangGraph** multi-agent pipeline — producing triage priorities, ATT&CK technique mapping, containment recommendations, and a regulatory compliance posture report.

> **Important:** This is a research prototype. It does not send packets, execute attacks, contact real hospital systems, or make automated changes to infrastructure.

2. Architecture

...





3. ML Pipeline — Quantum + Classical

3.1 Quantum ML VQC Pipeline

Stage 1: Preprocessing (qml_preprocessing.json)

...

99 raw features

|
log1p transform on 19 heavy-tailed features
(flow_byts_s, totlen_fwd_pkts, fwd_blk_rate_avg, etc.)

|
StandardScaler (training-only statistics, 149,196 rows)

...

Stage 2: Autoencoder (best_qml_autoencoder_6q.pt)

...

99 scaled features

| Linear(99, 64) -> ReLU -> Linear(64, 6)

v

6-dimensional latent vector

|

Scale to $[-\pi, \pi]$ using training latent min/max

...

Stage 3: Variational Quantum Circuit (best_qml_vqc_6q.pt)

...

6 angle-embedded values

|

AngleEmbedding (6 qubits, rotation Y)

|

StronglyEntanglingLayers (4 layers x 6 qubits x 3 params)

|

6x PauliZ measurements

|

Linear(6, 10) -> 10-class prediction -> Attack Label

...

10 Attack Classes

| Index | Dataset Label | Canonical Name |

|-----|-----|-----|

| 0 | BaseLine | normal |

| 1 | Alice2 | alice2 |

| 2 | DevEva | deveva |

| 3 | Discov | recon |

| 4 | Hulk | dos |

5	Nmap recon
6	NosyN nosyn
7	Ransac ransomware
8	SlowLoris dos
9	SuperSpy superspy

> **Known Limitation:** The 6-qubit VQC has limited expressivity and currently exhibits a dominant-class bias toward `ransomware`. This is a known challenge with low-qubit quantum classifiers. Treat the VQC output as a research-grade signal — not a production classifier.

3.2 Classical LightGBM Model

The classical model (`best\_regularized\_model.joblib`) is a trained LightGBM gradient boosting classifier:

- **Input:** Same 99-feature vector as QML
- **Output:** One of the 10 attack class labels
- **Reliability:** Significantly higher accuracy across all attack classes vs. the QML VQC
- **Role in Pipeline:** Runs alongside QML — both predictions shown side-by-side in the Model Comparison tab

Verified predictions on real dataset rows

True Attack Type	Classical	QML
-----	-----	-----
BaseLine	normal (correct)	ransomware
SlowLoris	dos (correct)	ransomware
Nmap	recon (correct)	ransomware
Ransac	ransomware (correct)	ransomware (correct)

3.3 Generating the QML Preprocessing Artifact

```
` `` powershell
$env:PYTHONPATH = "src"
.\.venv\Scripts\python.exe scripts\fit_qml_preprocessing.py `
--csv MasterDatasetProcessed_Clean.csv `
--log-features flow_duration,flow_byts_s,flow_pkts_s,totlen_fwd_pkts,flow_iat_mean,...
` ``
```

Generated from 149,196 training rows. Output: `qml\_preprocessing.json` (StandardScaler stats + latent bounds).

4. Dataset & Feature Engineering

4.1 Dataset

****File:**** `MasterDatasetProcessed\_Clean.csv`
****Size:**** ~84 MB, 149,196+ rows

4.2 Data Sources Combined

Source	Features
CICFlowMeter	Network flow metrics (packets, bytes, IAT, flags)
Wazuh	OS event volume, severity, high-severity count
Sysmon	Process event count
PAM/sudo	Privilege escalation events

| Port encoding | dst_port_443, dst_port_22, dst_port_80, etc. (one-hot) |
| Protocol encoding | proto_tcp, proto_udp, proto_other |

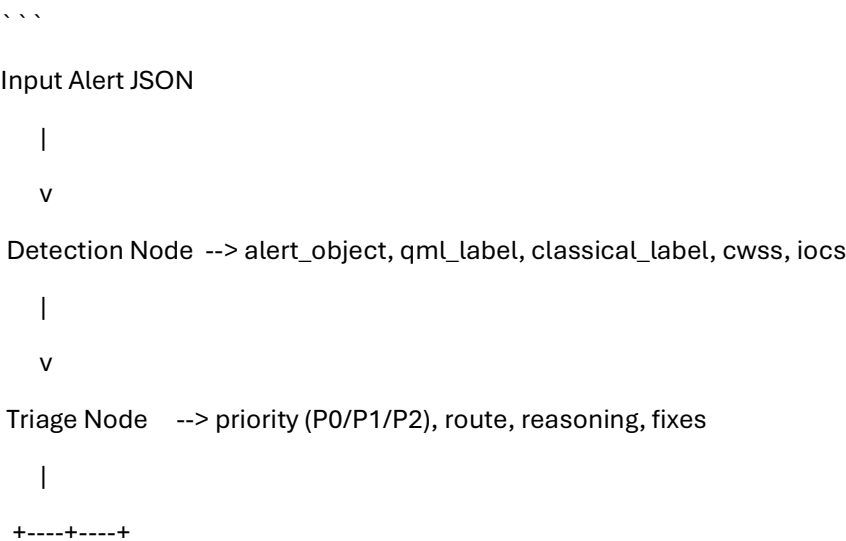
4.3 19 Heavy-Tailed Features (log1p Transformed)

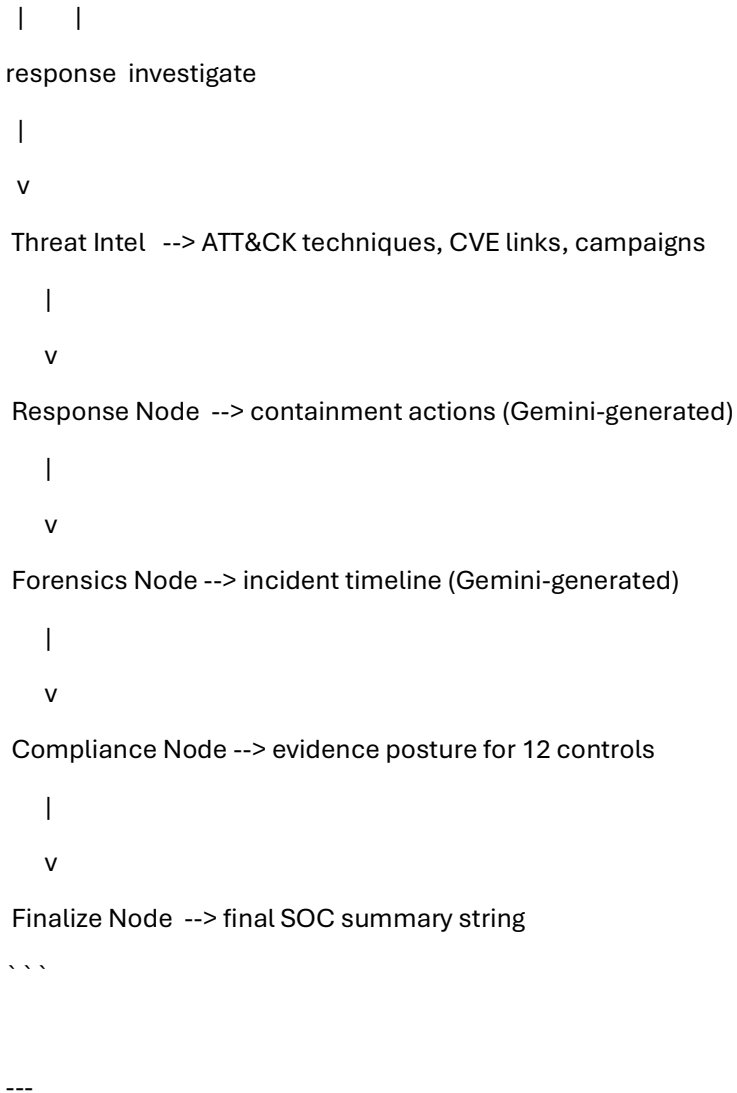
These features had skewness > 19 and were log-transformed before scaling:

```
...  
  
bwd_byts_b_avg, totlen_bwd_pkts, subflow_bwd_byts, subflow_fwd_byts,  
totlen_fwd_pkts, fwd_blk_rate_avg, bwd_blk_rate_avg, bwd_psh_flags,  
fwd_byts_b_avg, flow_byts_s, fwd_seg_size_avg, fwd_pkt_len_mean,  
fwd_act_data_pkts, pkt_len_var, fwd_psh_flags, fwd_header_len,  
bwd_pkts_b_avg, tot_fwd_pkts, subflow_fwd_pkts  
...  
  
---
```

5. Agentic Workflow

The system is built on **LangGraph** — a stateful, directed graph of agent nodes.





6. Agent Descriptions

Detection Agent

1. Calls Gemini to parse `message`, `source\_ip`, `asset\_type` from raw logs (if not provided)
2. Runs QML VQC -> `qml\_label`
3. Runs Classical LightGBM -> `classical\_label`
4. Log Analyzer: IOC extraction, attack vector, evidence strings, CWE candidates
5. CWSS-like scoring: label severity + clinical impact + evidence + IOC count
6. Composite confidence: weighted sum of IOC, evidence, CWSS, label, and telemetry signals

Triage Agent

```
| Condition | Priority |  
|-----|-----|  
| Critical impact + confidence >= 0.8 OR CWSS >= 9 | P0 |  
| Confidence >= 0.65 OR CWSS >= 6 | P1 |  
| Otherwise | P2 |
```

Calls Gemini for enriched reasoning and recommended fixes.

Threat Intel Agent

- Passes extracted IOCs to Gemini -> MITRE ATT&CK technique IDs + related campaigns
- Converts `CVE-\*` tokens to NVD links
- Fallback: basic IP-pattern heuristic (T1046)

Response Agent

- Calls Gemini with alert context -> 3-5 specific, actionable containment steps
- Fallback: generic firewall block + token revoke + isolation steps

Forensics Agent

- Calls Gemini with raw logs + triage priority -> 2-sentence attack timeline narrative
- Fallback: template string referencing ATT&CK phases

Compliance Agent

- Runs `assess\_compliance()` to evaluate 12 regulatory controls
- Calls Gemini for detailed, evidence-linked compliance explanation
- Returns checklist, metrics, and note

CWSS Scoring (scoring.py)

` ``

```

cwss_score = min(10, label_severity * 0.65 + impact_score + evidence_score + ioc_score)
...

```

Label severities: ransomware=9.0, malware=8.5, sql-injection=8.0, credential-theft=7.5, dos=7.0, brute_force=6.5, recon=4.0, unknown=2.0

Composite Confidence (scoring.py)

```

...

confidence = IOC_signal*0.25 + evidence_signal*0.25 + CWSS_signal*0.20 + label_signal*0.20
+ telemetry*0.10
...

---
```

7. Compliance Evidence System

7.1 Control Catalog (12 Controls)

Control ID	Framework	Applicability
----- ----- -----		
HIPAA-164.308(a)(1)	HIPAA Security Rule	hipaa_applicable
HIPAA-164.308(a)(6)	HIPAA Security Rule	hipaa_applicable
HIPAA-164.312(b)	HIPAA Security Rule	hipaa_applicable
HIPAA-164.316	HIPAA Security Rule	hipaa_applicable
NIST-CSF-2.0-RS.MA	NIST CSF 2.0	always
NIST-SP-800-61r3	NIST SP 800-61 Rev. 3	always
GDPR-ART32	GDPR Article 32	gdpr_applicable
GDPR-ART33	GDPR Article 33	gdpr_applicable
NIST-SP-800-66r2	NIST SP 800-66 Rev. 2	hipaa_applicable
ISO-27001-INCIDENT	ISO/IEC 27001:2022	iso_scope
SOC2-CC7	AICPA SOC 2	soc2_scope

| NIS2-ART21-23 | EU NIS2 Directive | nis2_applicable |

7.2 Evidence Status Values

| Status | Meaning |

|-----|-----|

| evidence_complete | All required evidence fields supplied |

| partial | Some fields present, some missing |

| not_evidenced | Control applicable but no evidence provided |

| not_applicable | Control not applicable per compliance_context |

7.3 How to Provide Evidence

```json

```
{
 "compliance_context": {
 "hipaa_applicable": true,
 "iso_scope": true,
 "gdpr_applicable": false
 },
 "compliance_evidence": {
 "HIPAA-164.308(a)(6)": {
 "incident_ticket": "INC-2026-1099",
 "timeline": "Attack occurred 01:00:00 - 01:02:30 UTC",
 "containment_record": "Host isolated at 01:02:30 UTC",
 "outcome_record": "Portal restored at 01:04:00 UTC",
 "approver": "SOC Lead",
 "integrity_hash": "sha256:..."
 }
 }
}
```

`, `

---

## ## 8. Streamlit Dashboard

**\*\*URL:\*\*** `http://localhost:8502`

### ### Tab Guide

| Tab | Content |

|-----|-----|

| Overview | Alert metadata, logs, detection evidence, IOCs, CWSS score |

| Detection | Full alert\_object JSON from Detection Agent |

| Model Comparison | QML vs Classical label, architecture notes, trust guidance |

| Triage | Priority (P0/P1/P2), confidence, Gemini reasoning, fixes |

| Threat Intel | ATT&CK techniques, CVE links, related campaigns |

| Response | Gemini-generated containment actions |

| Forensics | Gemini-generated attack timeline narrative |

| Compliance | Coloured control cards + clickable source links + raw table |

| LangGraph Trace | Per-node state updates from the actual graph run |

| SOC Summary | Final executive incident summary string |

---

## ## 9. Demo Log Files

| File | Scenario | Attack Type | Notes |

|-----|-----|-----|-----|

| log1.json | Normal backup traffic | BaseLine | Basic pipeline test |

| log2.json | Data exfiltration | Alice2 | |

| log3.json | Port scan / recon | Nmap | |

| log4.json | Ransomware on EHR server | Ransac | |

| log5.json | Ransomware + full compliance | Ransac | Shows all 4 compliance statuses |

| log6.json | Slow HTTP DoS on web portal | SlowLoris | Classical=dos, QML=ransomware (disagreement demo) |

### ### log5.json — Compliance Status Demo

| Control | Status |

|-----|-----|

| HIPAA-164.308(a)(6) | evidence\_complete |

| HIPAA-164.308(a)(1) | partial |

| HIPAA-164.312(b) | not\_evidenced |

| GDPR-ART32 | not\_applicable |

| ISO-27001-INCIDENT | evidence\_complete |

---

## ## 10. Running the Application

### ### Install

```
```powershell
```

```
cd d:\Quallki-agentic
```

```
.\.venv\Scripts\python.exe -m pip install -e .
```

```
```
```

### ### Start Streamlit

```
```powershell
```

```
$env:PYTHONPATH = "src"
```

```
.\.venv\Scripts\streamlit.exe run src/quallki_agentic/ui/streamlit_app.py --server.port 8502
` ` `
```

CLI Commands

```
` `` powershell
$env:PYTHONPATH = "src"

# Real log file
.\.venv\Scripts\python.exe -m quallki_agentic.cli --input log5.json

# Synthetic scenario
.\.venv\Scripts\python.exe -m quallki_agentic.cli --scenario ehr_ransomware
` ` `

---
```

11. Configuration Reference

Variable	Default	Purpose
----- ----- -----		
GEMINI_API_KEY	—	Authenticates Gemini LLM
GEMINI_MODEL	gemini-3.5-flash	LLM model
USE_GEMINI	true	Enables LLM enrichment
QML_MODEL_PATH	best_qml_vqc_6q.pt	6-qubit VQC checkpoint
QML_AUTOENCODER_PATH	best_qml_autoencoder_6q.pt	Autoencoder checkpoint
QML_PREPROCESSING_PATH	qml_preprocessing.json	Scaler + latent bounds
DEMO_MODE	true	Enables synthetic scenarios
ENABLE_EVENT_BUS	false	Redis event publishing
MESSAGE_BUS_BACKEND	inmemory	In-memory bus

12. Key Findings & Limitations

What Works

- Real log ingestion: upload any JSON with logs + features -> full 6-agent pipeline runs
- QML inference: 6-qubit VQC loaded via PennyLane + PyTorch, runs quantum circuit inference
- Classical inference: LightGBM correctly classifies all 10 attack types
- Gemini reasoning: all 5 LLM-enhanced agents call Gemini with the actual alert context
- Compliance mapping: 12 controls assessed per upload, clickable regulatory links in UI
- Model Comparison: both QML and Classical predictions shown side-by-side

Known Limitations

| Issue | Root Cause | Impact |

|-----|-----|-----|

| QML always predicts ransomware | 6-qubit VQC dominant-class collapse | Disagreement on all non-Ransac logs |

| Slow pipeline (~2 min/alert) | Sequential Gemini calls (5-6 per alert) | Rate-limiting bottleneck |

| Keyword-based log analysis | Deterministic heuristics, not a SIEM | Evidence quality depends on log verbosity |

| CWSS is a heuristic | Not an official CWSS/CVSS implementation | Useful for relative ranking only |

| Compliance is not legal advice | AI cannot certify compliance | Requires human validation |

Potential Next Steps

1. Retrain QML with more qubits (12-16) or better class-balancing
2. Add real SIEM adapter (Wazuh API, Splunk, Elastic)
3. Add automated unit and integration tests
4. Add analyst feedback capture and incident history

5. Add approval gates for clinical response actions
6. Add PHI minimization and audit logging for production

Documentation generated: 2026-08-21 | QUAL-KI Agentic SOC v0.1 (Research Prototype)